



Política de seguridad para BD y API REST

Proyecto: SalasMantenimiento | Materia: Arquitectura de Servicios | Unidad 4: Seguridad de una API REST

Objetivo

Definir la política de seguridad para el sistema SalasMantenimiento, estableciendo los roles con acceso a la base de datos y a la API REST, así como los privilegios y permisos permitidos en cada nivel. La política se basa en el principio de menor privilegio, asignando a cada rol únicamente los accesos necesarios para realizar sus funciones.

Roles definidos

Administrador	Técnico	Organizador
Rol con control total sobre la administración de salas, mantenimientos, actividades, materiales y gestión de usuarios.	Rol operativo encargado de consultar información general del sistema y administrar actividades y materiales relacionados con los mantenimientos.	Rol encargado de la gestión operativa de salas y mantenimientos, con permisos de consulta general y modificación limitada según las reglas del negocio.

Criterio general

La asignación de permisos se organiza por roles y se representa mediante matrices de acceso. En cada matriz, el símbolo ✓ representa un permiso concedido, ✗ representa un permiso denegado y N/A indica que la operación no aplica para el recurso.



Política de seguridad para la BD SalasMantenimiento

Rol: Administrador				
Colección / Vista	insert	update	find	remove
salas	✓	✓	✓	✓
mantenimientos	✓	✓	✓	✗
actividades	✓	✓	✓	✓
materiales	✓	✓	✓	✓
usuarios	✓	✓	✓	✓
salasView	N/A	N/A	✓	N/A
mantenimientosView	N/A	N/A	✓	N/A
actividadesView	N/A	N/A	✓	N/A
materialesView	N/A	N/A	✓	N/A
usuariosView	N/A	N/A	✓	N/A

Rol: Técnico				
Colección / Vista	insert	update	find	remove
salas	✗	✗	✓	✗
mantenimientos	✗	✗	✓	✗
actividades	✓	✓	✓	✓
materiales	✓	✓	✓	✓
usuarios	✗	✗	✗	✗
salasView	N/A	N/A	✓	N/A
mantenimientosView	N/A	N/A	✓	N/A
actividadesView	N/A	N/A	✓	N/A
materialesView	N/A	N/A	✓	N/A
usuariosView	N/A	N/A	✓	N/A



Política de seguridad para la BD SalasMantenimiento (continuación)

Rol: Organizador				
Colección / Vista	insert	update	find	remove
salas	✗	✓	✓	✗
mantenimientos	✓	✓	✓	✗
actividades	✗	✗	✓	✗
materiales	✗	✗	✓	✗
usuarios	✗	✗	✗	✗
salasView	N/A	N/A	✓	N/A
mantenimientosView	N/A	N/A	✓	N/A
actividadesView	N/A	N/A	✓	N/A
materialesView	N/A	N/A	✓	N/A
usuariosView	N/A	N/A	✓	N/A

Criterios de seguridad a nivel BD

1	Las vistas (salasView, mantenimientosView, actividadesView, materialesView, usuariosView) serán de solo lectura.	4	El rol Organizador podrá consultar información general y administrar salas y mantenimientos según las reglas del negocio.
2	El rol Administrador tendrá control total sobre la administración del sistema.	5	La colección usuarios será utilizada para la autenticación básica y la asignación de roles.
3	El rol Técnico podrá operar únicamente sobre actividades y materiales, además de consultar salas y mantenimientos.	6	Los accesos a la BD deben asignarse respetando el principio de menor privilegio.



Política de seguridad de la API REST Salas API

Operación	Endpoint	HTTP	Administrador	Técnico	Organizador
Crear sala	/salas	POST	✓	✗	✗
Listar salas	/salas	GET	✓	✓	✓
Consultar sala por id	/salas/{id}	GET	✓	✓	✓
Consultar salas por estatus	/salas/estatus/{estatus}	GET	✓	✓	✓
Modificar sala	/salas/{id}	PUT	✓	✗	✓
Eliminar sala	/salas/{id}	DELETE	✓	✗	✗
Asignar mantenimiento	/mantenimientos	POST	✓	✗	✓
Listar mantenimientos	/mantenimientos	GET	✓	✓	✓
Consultar mantenimientos por idSala	/mantenimientos/sala/{idSala}	GET	✓	✓	✓
Consultar mantenimiento por id	/mantenimientos/{id}	GET	✓	✓	✓
Consultar mantenimientos por estatus	/mantenimientos/estatus/{estatus}	GET	✓	✓	✓



Política de seguridad de la API REST Salas API (continuación)

Operación	Endpoint	HTTP	Administrador	Técnico	Organizador
Modificar mantenimiento	/mantenimientos/{id}	PUT	✓	✗	✓
Crear actividad	/actividades	POST	✓	✓	✗
Listar actividades	/actividades	GET	✓	✓	✓
Consultar actividad por id	/actividades/{id}	GET	✓	✓	✓
Modificar actividad	/actividades/{id}	PUT	✓	✓	✗
Eliminar actividad	/actividades/{id}	DELETE	✓	✓	✗
Crear material	/materiales	POST	✓	✓	✗
Listar materiales	/materiales	GET	✓	✓	✓
Consultar material por id	/materiales/{id}	GET	✓	✓	✓
Modificar material	/materiales/{id}	PUT	✓	✓	✗
Eliminar material	/materiales/{id}	DELETE	✓	✓	✗

Reglas generales de autorización en la API

- 1 Todo acceso a la API REST requerirá autenticación básica mediante usuario y contraseña.
- 2 Una vez autenticado el usuario, la API validará el rol asignado antes de permitir la ejecución de la operación solicitada.
- 3 Los permisos sobre endpoints deberán respetar la matriz anterior.
- 4 Si un usuario intenta acceder a una operación no permitida para su rol, la API responderá con HTTP 403 Forbidden.
- 5 Si el usuario no proporciona credenciales válidas, la API responderá con HTTP 401 Unauthorized.



Observaciones finales

Base de implementación

- 1 La presente política servirá como base para la configuración de roles y usuarios en MongoDB, la implementación del proceso de autenticación básica, la autorización por roles en FastAPI y la configuración posterior de rate limiting.
- 2 Esta política se alinea con la documentación funcional ya existente del proyecto y con las reglas de negocio definidas para cada recurso.

Leyenda

✓ Permiso concedido	✗ Permiso denegado	N/A No aplica
---------------------	--------------------	---------------

Documento elaborado con una estructura similar al formato de matriz de roles proporcionado como ejemplo para la Unidad 4, integrando la política de base de datos y la matriz de autorización de endpoints para el proyecto SalasMantenimiento.